Smiles S.A

RELATÓRIO DE AUDITORIA
N°. 2016-1/3488

Assunto: AIC - COBIT - S.PO2 - Definir Arquitetura de Informação

Período da Auditoria:
08/08/2016 a 06/09/2016

Smiles S.A

ÍNDICE

1 INTRODUÇÃO 3
2 OBJETIVO 3
3 ESCOPO 3
4 CONCLUSÃO 3
5 DETALHAMENTO DE RISCOS E CONTROLES 3
5.1 SPO2.R01.SPO2.C01 3
5.1.1 SPO2.C01 3

Smiles S.A

1 INTRODUÇÃO

Teste de Efetividade dos Controles do Processo do Cobit - Definir Arquitetura de Informação a fim de garantir de o controle mitiga os riscos vinculados

2 OBJETIVO

Nosso trabalho teve como objetivo a verificação quanto à efetividade dos controles do Processo do Cobit - Definir Arquitetura de Informação para mitigar os riscos vinculados com as atividades desse Processo, no contexto da avaliação da Administração (testes da Administração) para certificação 404-SOX.

3 ESCOPO

Avaliar se os procedimentos para estabelecer e manter um modelo de arquitetura da informação estão sendo adequadamente realizadas.

4 CONCLUSÃO

Os controles testados, definidos na Matriz de Riscos e Controles, não estão sendo executados de forma efetiva. Nossos testes revelou uma deficiência relevante que coloca em risco o ambiente de controles gerais da área de TI, conforme demonstramos a seguir.

. Existem objetivos de controle do Cobit 4.0 relevantes que não estão sendo contemplados na matriz de risco deste processo, tais como: (i) PO2.2 Dicionário de dados corporativo e regras de sintaxe de dados; (ii) PO2.3 Esquema de Classificação de Dados e (iii) PO2.4 Gerenciamento de Integridade.

5 DETALHAMENTO DE RISCOS E CONTROLES

5.1 SPO2.R01.SPO2.C01

Descrição Risco:	A infraestrutura não atender a demanda, não tendo alinhamento com as estratégias de TI e do Negócio

5.1.1 SPO2.C01

Descrição Controle:	As novas demandas passam pelo Comite de Arquitetura, para criação/aprovação da arquitetura. Comite de Arquitetura revisa e aprova o modelo desenhado para cada projeto, antes do seu inicio, validando se está alinhado com as estratégias de TI e do negócio. O Comite ocorre semanalmente.
Efetividade:	Inefetivo

Ponto:

NCONF-01 Existem objetivos de controles relevantes que não estão sendo contemplados na matriz de risco deste processo, conforme demonstramos a seguir:

PO2.2 Dicionário de Dados Corporativos e Regras de Sintaxe de Dados
Manter um dicionário de dados corporativos que incorpore as regras de sintaxe de dados da organização. Este dicionário permite o compartilhamento dos elementos de dados entre aplicativos e sistemas, promove um entendimento comum de dados entre a TI e os usuários do negócio, e previne a criação de elementos de dados incompatíveis.

PO2.3 Esquema de Classificação de Dados
Estabelecer um esquema de classificação de dados aplicável a toda a organização com base na importância e na confidencialidade dos dados corporativos (por exemplo: público, confidencial, altamente secreto). Esse esquema inclui detalhes sobre os proprietários dos dados, definição de níveis apropriados de segurança, controle de proteção, uma breve descrição dos requisitos de retenção e destruição dos dados, importância e confidencialidade. É utilizado como base para aplicação de controles, tais como controles de acesso, arquivamento ou criptografia.

PO2.4 Gerenciamento de Integridade
Definir e implementar procedimentos que assegurem a integridade e consistência de todos os dados armazenados na forma eletrônica, tais como banco de dados, data warehouses e arquivos de dados.

Verificamos ainda que não foi definido como controle chave deste processo a coleta, divulgação e acompanhamento dos indicadores.

Recomendação:

NCONF-01 Recomendamos que este processo seja revisado e atualizado visando contemplar os objetivos de controles previstos no framework no COBIT 4 (citados anteriormente). Adicionalmente, devem ser definidos, coletados e acompanhados indicadores para este processo, a título de exemplo citamos os seguintes indicadores:

. Percentual de aplicações que não estão em conformidade com a arquitetura da informação.

. Percentual de elementos de dados que não tem um proprietário designado.

. Percentual de elementos de dados não classificado (Exemplo: Público, Confidencial e Altamente Sigiloso).

. Percentual de elementos de dados redundantes/duplicados.

PA-01 Recomendamos que após a reunião semanal do Comitê de Arquitetura, seja criado algum tipo de formalização a respeito da ocorrência ou não da modelagem de dados.

Smiles S.A

Envolvidos na Auditoria:

_____
Delio Goldner
Revisor

_____
Marcio Mendes
Revisor

_____
Andre Luis Gonçalves Fernandes
Auditor Responsável

_____
Juliana Genio Dantonio
Aprovador 1a Alçada